



CYBERSECURITY FOR PROFESSIONALS BOOTCAMP

Capstone Cybersecurity for Professionals Process

Purpose

The capstone serves as the culminating training activity where participants demonstrate their technical and professional skills through a team-based project and presentation before transitioning to on-the-job activities.

Capstone Planning

Introduce the Capstone Project

Timing: During trainer preparation and learner orientation. Or week before hybrid schedule.

Instructor Responsibilities

- Review the capstone project, deliverables, and rubric.
- Explain project expectations during the first week of training.
- Share examples of successful capstone presentations when available.
- Reinforce that the capstone is a major component of the final evaluation.

TAM / Program Manager Responsibilities

- Confirm the training team shares:
 - Capstone project documentation
 - Evaluation rubric
 - Presentation expectations
- Confirm anticipated capstone presentation dates with client stakeholders.
- Add capstone milestones to the program schedule.

Team Formation

Timing

Approximately 50-60% through the bootcamp. This allows instructors sufficient time to assess:

- Technical aptitude
- Participation
- Leadership potential
- Collaboration skills
- Attendance and professionalism

Team Assignment Guidelines

Recommended Team Size

Cohort Size	Team Structure
8-12 learners	Teams of 3-4
13-18 learners	Teams of 3-5

19-25 learners	Teams of 4-5
----------------	--------------

Team Formation Criteria

The instructor should create balanced teams based on:

Technical Mix

- Strong performers paired with developing learners
- Mix of technical strengths

Professional Skills Mix

- Strong communicators distributed across teams
- Emerging leaders spread across multiple teams

Engagement Levels

- Avoid placing all high performers on one team.
- Avoid placing all struggling learners together.

Role Assignment Each team should identify:

- Team Lead
- Technical Lead
- Presentation Lead
- Documentation Lead

One learner may hold multiple roles for smaller teams.

Ownership

Primary Owner: Instructor

The instructor has the best visibility into learner capabilities and should make final team assignments. TAM may provide input regarding behavioral or professionalism concerns

Capstone Execution

Timing

Final 1-2 weeks of training, depending on program length.

Instructor Responsibilities

- Manage day-to-day project execution.
- Conduct project check-ins.
- Coach teams through technical challenges.
- Monitor contribution levels across team members.
- Ensure all learners participate meaningfully.
- Review project artifacts and drafts.

TAM Responsibilities

- Monitor overall engagement.

- Address professionalism concerns.
- Support any learner escalations.
- Ensure project milestones remain on schedule.

Presentation Logistics

Primary Logistics Owner

Lead Instructor

The instructor manages:

- Presentation order
- Timing allocations
- Technical readiness checks
- Project evaluation
- Q&A facilitation

TAM Responsibilities

The TAM coordinates:

- Client invitations
- Observer attendance
- Calendar management
- Recording arrangements
- Distribution of presentation schedule

Current guidance already places presentation coordination and client logistics with the TAM while instructors facilitate the actual presentation sessions.

Presentation Standards

- Every learner must actively participate.
- Every learner must speak during the presentation.
- Recommended presentation slot:
 - 15-20 minute presentation
 - 5-10 minute Q&A
 - 5 minute transition between teams

For larger cohorts, multiple learners should present as a single project team rather than individual presentations. This approach is already referenced in trainer planning discussions.

Evaluation

Instructor Responsibilities

- Complete scoring rubric.
- Assess:
 - Technical quality
 - Problem solving

- Teamwork
- Presentation effectiveness
- Documentation quality

TAM Responsibilities

- Track outcomes.
- Identify readiness concerns.
- Document behavioral feedback.
- Share results with stakeholders as appropriate.

RACI Summary

Activity	Instructor	TAM	Program Manager	Client
Introduce Capstone	R	C	C	I
Create Teams	R	C	I	I
Manage Project Work	R	C	I	I
Coach Participants	R	C	I	I
Schedule Presentations	C	R	I	I
Invite Client Observers	I	R	I	C
Facilitate Presentations	C	R	I	I
Grade Projects	R	I	I	C
Share Outcomes	C	R	C	I

R = Responsible | A = Accountable | C = Consulted | I = Informed

Capstone Background

A fictional regional bank used for this simulation operates a hybrid IT environment typical of a mid-size regulated financial institution: Windows Server domain infrastructure supporting core banking and email systems, Linux servers supporting customer-facing web applications, a segmented network protected by next-generation firewalls, and a growing reliance on AI-assisted tooling (Microsoft Security Copilot-style assistants) and Power BI reporting to keep pace with alert volume and regulatory reporting demands.

Like most banks, the bank is a high-value target. Its SOC has historically been reactive: alerts pile up in a queue, investigations are inconsistent across analysts, encryption and certificate management is uneven across services, and fraud indicators are tracked in scattered spreadsheets rather than a governed dashboard. Internal audit and the bank's Chief Risk Officer (CRO) have flagged this as a gap heading into the next regulatory exam.

Leadership has asked your cohort, organized into security teams, to stand up, harden, monitor, and defend a representative slice of the bank's environment, and to demonstrate that your team can detect and respond to a real attack the way a bank SOC is expected to: quickly, correctly, and with a defensible audit trail.

The Problem

Each team must design, harden, and operate a small but representative banking environment, then detect and respond to a live, multi-stage simulated attack against it using every discipline covered in this bootcamp, not just SOC tooling.

Your solution must:

1. Harden a mixed Linux and Windows environment representing the bank's application and domain infrastructure, applying least-privilege, patching, and system-hardening practices from Weeks 1–2.
2. Design and implement network segmentation and next-generation firewall rules that isolate the customer-facing tier from internal systems (Week 5).
3. Implement TLS and certificate management for at least one customer-facing service, including a working chain of trust and evidence you can explain the handshake (Week 4).
4. Stand up detection content in a SIEM (Splunk and/or Sentinel-style workspace) and use an AI-assisted triage workflow to investigate at least one alert end to end, including verifying the AI's evidence before acting (Week 7).
5. Build a governed security/fraud dashboard in Power BI, including at least one Copilot-generated visualization or summary, that a bank stakeholder could use to answer “what is our current risk posture” (Week 8).
6. Account for the human element: your incident scenario must include a social-engineering vector, and your remediation must include a control or awareness measure that addresses it, not just a technical fix (Week 9).
7. Produce documentation, an incident timeline, and a remediation record that would satisfy an internal auditor or examiner, including references to applicable governance frameworks (Week 7, Day 5).

Constraints and Starting Point

Each team will be provided with:

8. A small pre-built lab environment: 1–2 Windows Server hosts (domain controller and/or file server), 1–2 Linux hosts (customer-facing web app and a jump/admin host), and a firewall/virtual appliance the team controls.
9. A starter certificate authority or the ability to generate one, for issuing and managing TLS certificates.
10. Access to a SIEM workspace (Splunk and/or Microsoft Sentinel) pre-loaded with baseline logs, plus access to an AI-assisted triage tool (Security Copilot-style assistant or instructor-approved equivalent).
11. A sample banking-style dataset (authentication logs, transaction/wire-transfer logs, and alert history) for the Power BI dashboard.

12. A documented “inject” schedule known only to the instructor: the attack scenario will be introduced partway through the capstone window without advance notice of timing.

Teams are not permitted to rebuild the environment from scratch or to bypass the firewall, SIEM, or PKI components provided. The goal is to operate and defend the environment as given, the same way a new hire would inherit an existing bank environment.

The Attack Scenario (Instructor-Injected)

At an undisclosed point during the capstone window, the instructor (acting as red team / injects controller) will introduce a multi-stage incident modeled directly on the fraud and threat scenarios covered throughout the course. A representative version of the scenario:

13. Initial access: A simulated phishing or pretexting email (Week 9) targets a the bank employee and results in compromised credentials.
14. Escalation: The compromised account is used to attempt lateral movement toward systems handling wire-transfer approvals, generating anomalous authentication activity (impossible travel, failed logins) visible in the SIEM (Week 7).
15. Business impact: A business email compromise (BEC) style message attempts to trigger a fraudulent wire transfer, similar to the scenarios referenced across Weeks 4, 7, and 8.
16. Certificate/network angle: A misconfigured or expiring certificate, or a firewall rule gap, plays a role in either the attack path or the team's ability to detect it mirroring the Week 4 TLS-misconfiguration lab.

Teams must detect the activity through their own monitoring (not because the instructor tells them), triage it using their AI-assisted workflow, contain and remediate it using documented, repeatable actions, and verify recovery.

Expected Outcome

By the end of the capstone, each team's environment should demonstrate:

17. A hardened Linux/Windows environment with documented baseline configurations and evidence of least-privilege enforcement.
18. Working network segmentation and firewall rules mapped to a simple network diagram, with rules justified in plain language.
19. At least one properly issued and configured TLS certificate with an explainable chain of trust.
20. SIEM detection content (searches, correlation rules, or analytics) that actually fired during the injected scenario, plus a documented AI-assisted triage of that alert.
21. A completed incident timeline from detection through containment, remediation, and verified recovery, including the human-factor control that was added or reinforced.
22. A Power BI dashboard, built and refreshed with real data from the exercise, that a non-technical stakeholder could read in under two minutes.

23. A short compliance note connecting the incident and response to at least one governance/regulatory concept covered in Week 7, Day 5 (e.g., model risk management guardrails for the AI tool used, or relevant data-privacy considerations).

Final Demonstration Scenario

Your final presentation must include a live walkthrough of the incident, told chronologically:

A phishing email lands in an employee inbox and credentials are compromised. Anomalous authentication activity appears in the SIEM. Your team's detection content fires, an analyst begins AI-assisted triage, and the team validates the AI's evidence before escalating. The team identifies an attempted fraudulent wire transfer tied to the compromised account, contains the incident (disabling the account, tightening a firewall rule, or rotating a certificate as appropriate), and confirms recovery. The team then shows the Power BI dashboard reflecting the incident and closes with the human-factor control put in place to reduce recurrence.

Your team must be able to explain:

24. How the activity was first detected, and by what specific piece of monitoring or content.
25. What the AI-assisted tool surfaced, what evidence the team verified before trusting it, and where a human judgment call was still required.
26. What technical and human-factor controls were applied to contain and prevent recurrence.
27. How the team would explain this incident, in plain language, to the CRO and to frontline staff.

Team Structure and Roles

Teams are assigned by the instructor at approximately the 50–60% mark of the bootcamp, based on demonstrated technical aptitude, participation, and collaboration, not self-selected. Team size will depend on cohort size.

One learner may hold multiple roles on smaller teams. Every learner is expected to be able to speak to any part of the solution during Q&A.

Deliverables

28. A team repository or shared workspace containing configuration exports, firewall rule sets, SIEM detection content, and Power BI files, with a clear README.
29. A network/architecture diagram showing segmentation, the firewall, and where each provided host sits.
30. Evidence of Linux/Windows hardening (baseline checklist, before/after configuration, or hardening script).
31. Certificate/PKI artifacts: CSR, issued certificate, and a short written explanation of the chain of trust.
32. SIEM detection content and screenshots/exports of the alert(s) that fired during the injected scenario.
33. A written incident timeline covering detection, AI-assisted triage, escalation, containment, remediation, and recovery.

34. A published or exported Power BI dashboard built from real exercise data.
35. A one-page compliance/governance note connecting the response to at least one framework or guardrail from Week 7, Day 5.
36. Final presentation deck (organization-wide format) capturing the incident story, what worked, what didn't, and what the team would do differently.

Working Assumptions and Guardrails

37. All credentials and secrets must be handled through an approved secrets mechanism never committed or displayed in plaintext during the presentation.
38. Direct manual changes to hosts are permitted for diagnosis but should be reflected back into documented configuration, not left as untracked drift.
39. The injected attack scenario is designed to be detectable through the monitoring the team builds if a team cannot detect it, that is itself a finding to be discussed honestly in the presentation, not concealed.
40. Pair work and rotation across roles are encouraged so every team member can walk through any part of the solution.
41. Every learner must speak during the final presentation.

Presentation Logistics

Presentations take place during Week 10, Days 4–5, to the full training organization, including client/stakeholder observers where applicable. Recommended slot per team:

42. 15–20 minute presentation
43. 5–10 minute Q&A
44. 5 minute transition between teams

For larger cohorts, all team members present together as a single project team rather than individually. The lead instructor manages presentation order, timing, and Q&A facilitation; the Program/Training Manager coordinates stakeholder invitations, calendar logistics, and recording.